

Phase 3: Defensive Strategy Implementation

Phase 3 eliminates the SSH brute-force weakness demonstrated in Phase 1. The lab contains a Kali attacker VM and a Metasploitable-3 victim VM. Initially, the victim accepted unlimited password guesses on the default SSH port, allowing a simple dictionary script to gain shell access.

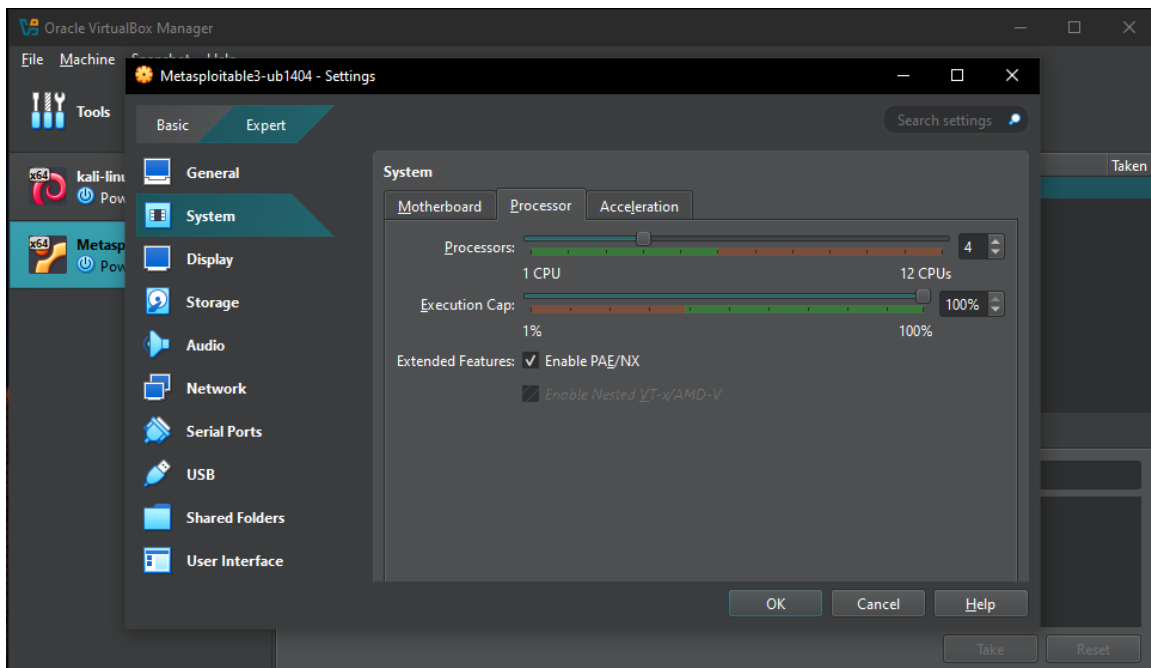
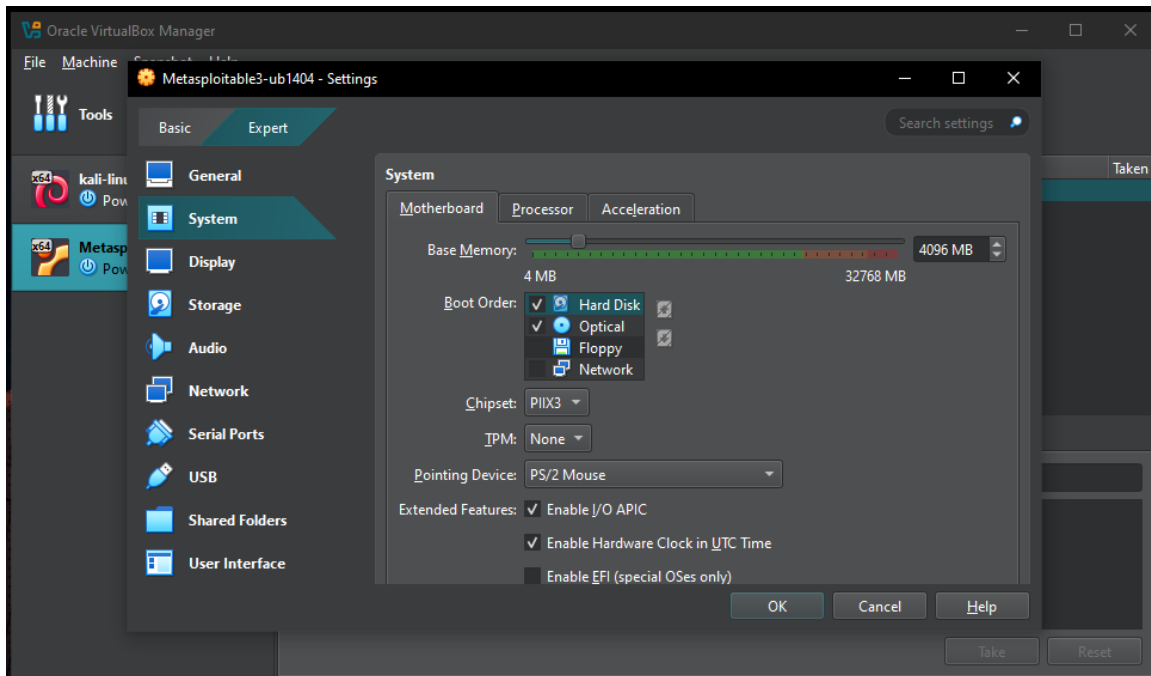
Three defenses were applied:

1. Fail2Ban now monitors `/var/log/auth.log` and bans an IP for one hour after three failed SSH logins.
2. OpenSSH was moved from port 22 to port 2222 to reduce automated scans that target the default port. Password authentication remains enabled to preserve ease of access for administrators.
3. UFW was activated with a default-deny policy, permitting only SSH on port 2222 and all outgoing traffic.

After deployment the brute-force script failed, the attacker's IP was automatically banned, and a nmap scan showed port 22 closed with no other inbound services exposed. The system now offers a single, rate-limited SSH entry point guarded by a firewall, meeting the project's defensive objectives while retaining password-based logins for legitimate use.

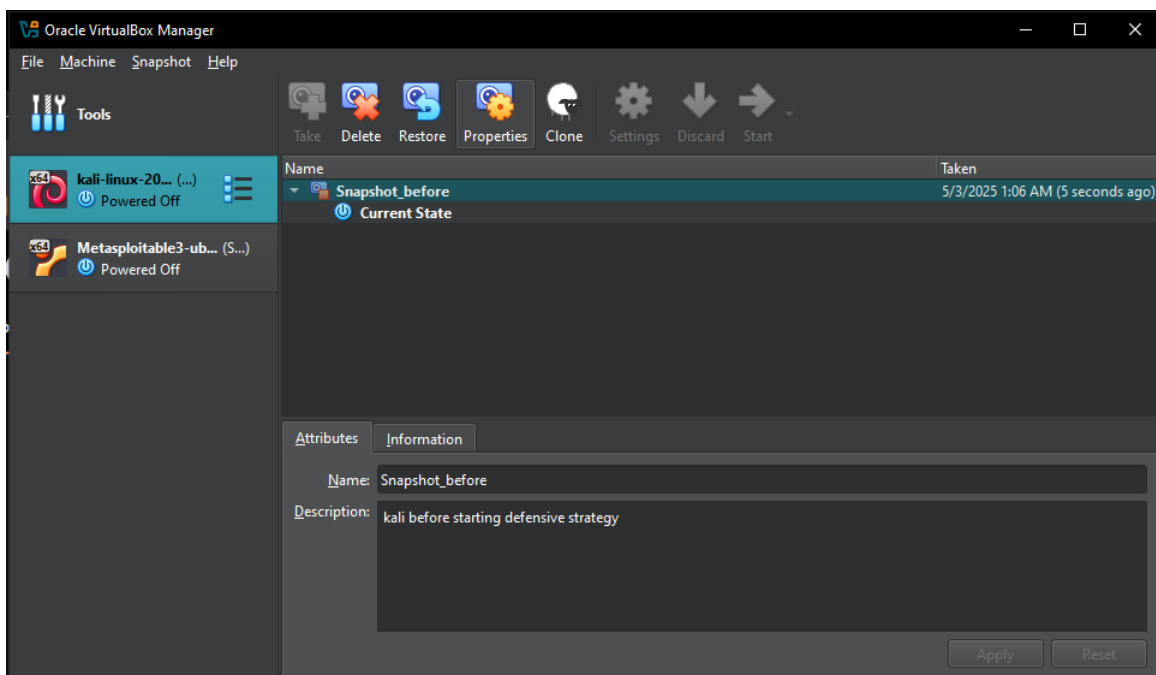
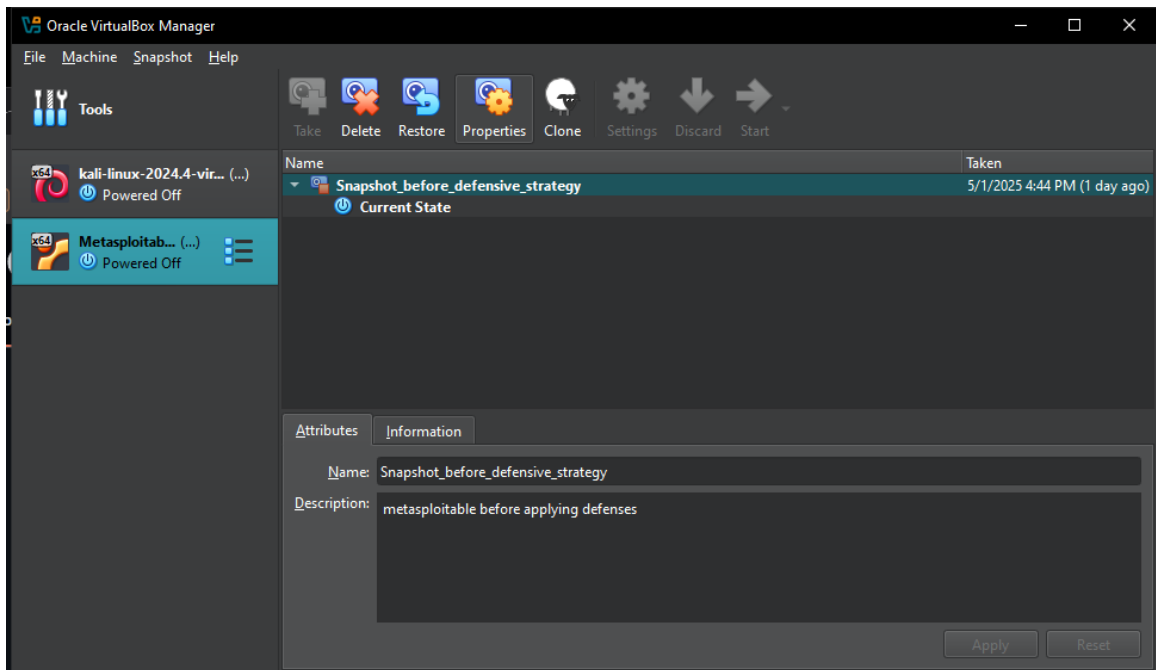
Step 1: Document initial VM resources

Metasploitable-3 is given 4 GB of RAM and 4 CPU cores. This is enough to run additional security software while avoiding performance issues. The same is allocated to the Kali VM.



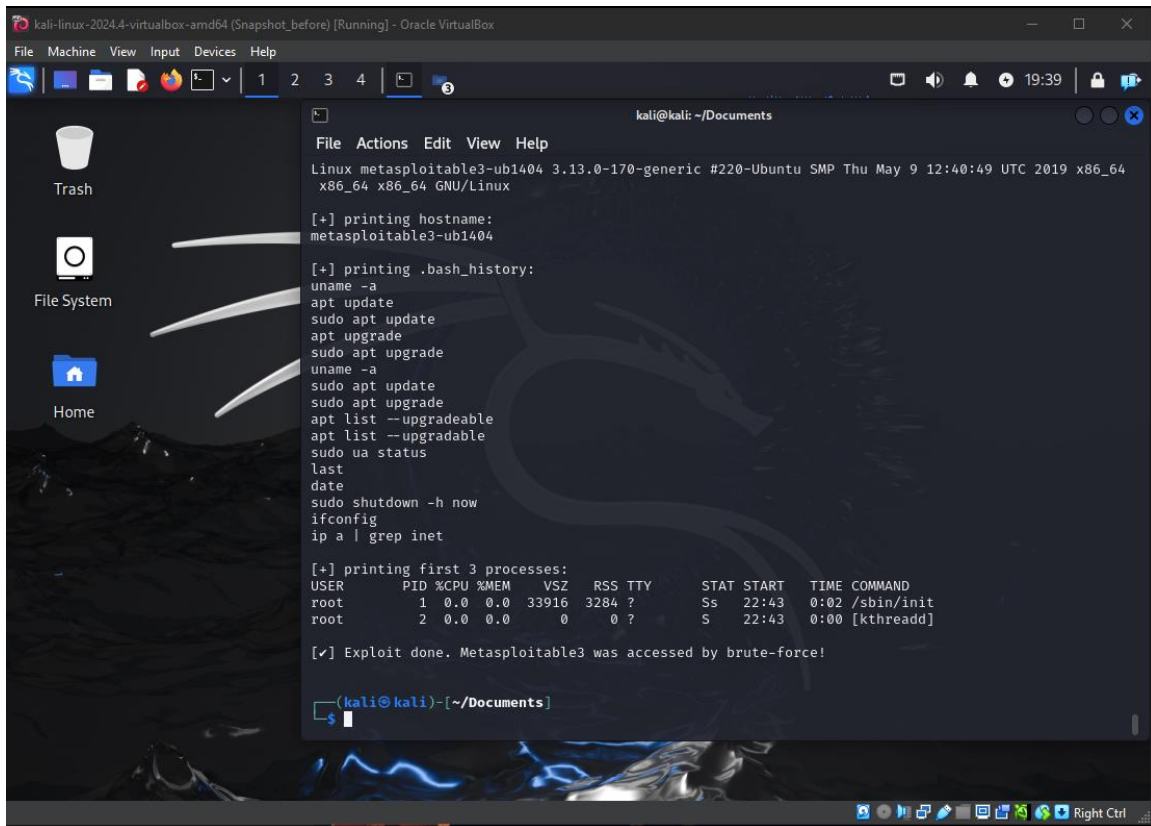
Step 2: Take rollback snapshots

Before any changes, snapshots are created for both VMs. This guarantees an easy restore point if later steps break connectivity.



Step 3: Re-confirm the vulnerability

The original Phase 1 brute-force script is executed from Kali. It succeeds and prints “Exploit done” proving the target is still exposed.



Step 4: Obtain root on the victim

A privileged shell is opened with “sudo -l”. Root access is required to install and configure defensive tools.

```
vagrant@metasploitable3-ub1404:~$ sudo -i  
root@metasploitable3-ub1404:~# _
```

Step 5: Install Fail2Ban and UFW

“apt-get install fail2ban ufw -y” pulls both packages over the NAT adapter. No errors occur.

```
root@metasploitable3-ub1404:~# apt-get install fail2ban ufw -y_
```

Step 6: Create a custom Fail2Ban jail

A file named “/etc/fail2ban/jail.d/ssh-hardening.conf” is written. The jail watches “/var/log/auth.log”, bans an IP after three failures, and keeps the ban for one hour.

```

root@metasploitable3-ub1404:~# cat >/etc/fail2ban/jail.d/ssh-hardening.conf <<'EOF'
[sshd]
enabled = true
port = 22
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
findtime = 600
bantime = 3600
EOF
root@metasploitable3-ub1404:~#

```

Step 7: Activate and verify Fail2Ban

The service is restarted. “fail2ban-client” now lists the default ssh jail and the new sshd jail. Configuration values match the file.

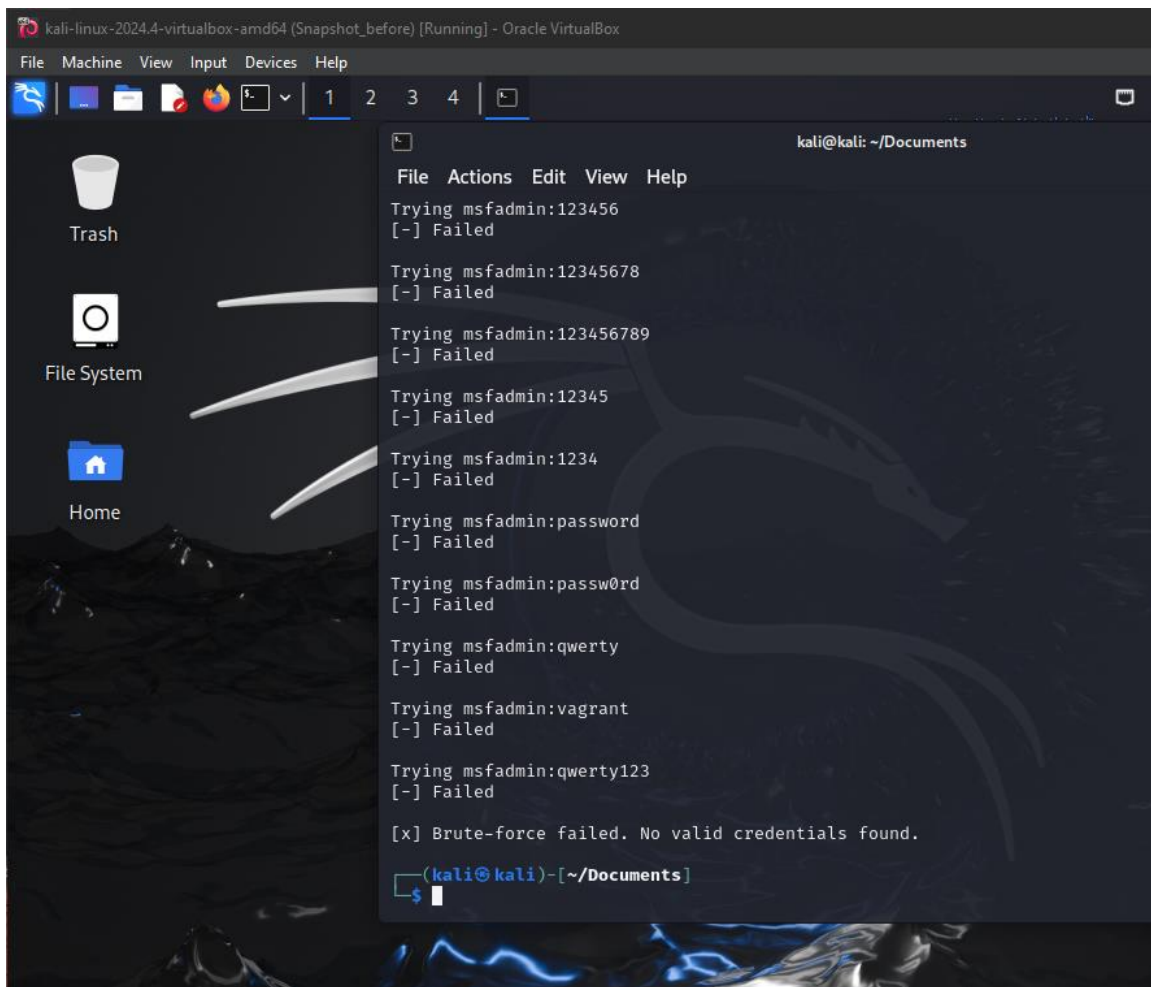
```

root@metasploitable3-ub1404:~# fail2ban-client status sshd
ERROR NOK: ('sshd',)
Sorry but the jail 'sshd' does not exist
root@metasploitable3-ub1404:~# fail2ban-client status ssh
Status for the jail: ssh
|- filter
| |- File list:      /var/log/auth.log
| |- Currently failed: 0
| |- Total failed:   0
|- action
| |- Currently banned: 0
| |- IP list:
| |- Total banned:    0
root@metasploitable3-ub1404:~# ls -l /etc/fail2ban/jail.d/ssh-hardening.conf
-rw-r--r-- 1 root root 117 May  3 00:50 /etc/fail2ban/jail.d/ssh-hardening.conf
root@metasploitable3-ub1404:~# service fail2ban restart
* Restarting authentication failure monitor fail2ban
root@metasploitable3-ub1404:~# fail2ban-client status
Status
|- Number of jail:      2
|- Jail list:          sshd, ssh
root@metasploitable3-ub1404:~# fail2ban-client status sshd
Status for the jail: sshd
|- filter
| |- File list:      /var/log/auth.log
| |- Currently failed: 0
| |- Total failed:   0
|- action
| |- Currently banned: 0
| |- IP list:
| |- Total banned:    0
root@metasploitable3-ub1404:~# fail2ban-client get sshd maxretry
3
root@metasploitable3-ub1404:~#

```

Step 8: Retest the attack

The brute-force script is run again from Kali. All attempts fail; no credentials are found. This shows the defence is effective at the default port.



Step 9: Confirm the ban

`fail2ban-client status sshd` shows one IP, which is Kali's IP, currently banned.
Total failed logins recorded: 4.

```
root@metasploitable3-ub1404:~# fail2ban-client status sshd
Status for the jail: sshd
|- filter
| |- File list:      /var/log/auth.log
| |- Currently failed: 1
| `-- Total failed: 4
`- action
    |- Currently banned: 1
    | `-- IP list:      172.28.128.50
    `-- Total banned: 1
root@metasploitable3-ub1404:~#
```

Step 10: Move SSH to port 2222

The SSH daemon is reconfigured to listen on 2222. The service restarts cleanly. A matching UFW allow rule for 2222/tcp is added.

```
root@metasploitable3-ub1404:~# sed -i 's/^#\?Port.*/Port 2222/' /etc/ssh/sshd_config
root@metasploitable3-ub1404:~# sudo service ssh restart
ssh stop/waiting
ssh start/running, process 2911
root@metasploitable3-ub1404:~# ufw allow 2222/tcp
Rules updated
Rules updated (v6)
root@metasploitable3-ub1404:~# _
```

Step 11: Lock down the firewall

Default policy is set to “deny incoming.” Only port 2222 is permitted. Firewall status shows an active profile with a single allow rule.

```
root@metasploitable3-ub1404:~# ufw default deny incoming
Default incoming policy changed to 'deny'
(be sure to update your rules accordingly)
root@metasploitable3-ub1404:~# ufw default allow outgoing
Default outgoing policy changed to 'allow'
(be sure to update your rules accordingly)
root@metasploitable3-ub1404:~# ufw allow 2222/tcp
Skipping adding existing rule
Skipping adding existing rule (v6)
root@metasploitable3-ub1404:~# ufw enable
Firewall is active and enabled on system startup
root@metasploitable3-ub1404:~# ufw status verbose
Status: active
Logging: on (low)
Default: deny (incoming), allow (outgoing), deny (routed)
New profiles: skip

To Action From
--
2222/tcp ALLOW IN Anywhere
2222/tcp (v6) ALLOW IN Anywhere (v6)

root@metasploitable3-ub1404:~# _
```

Step 12: Align Fail2Ban with the new port

The jail file is updated so “port = 2222”. This ensures the same brute-force protection remains in place on the new port.

```
root@metasploitable3-ub1404:~# cat >/etc/fail2ban/jail.d/ssh-hardening.conf <<'EOF'
[sshd]
enabled = true
port = 2222
filter = sshd
logpath = /var/log/auth.log
maxretry = 3
findtime = 600
bantime = 3600
EOF
root@metasploitable3-ub1404:~#
```

Step 13: Verify port closure

From Kali, an nmap scan of port 22 on the victim reports the host as down. This confirms port 22 is closed and no longer answers.

```
(kali@kali)-[~/Documents]
$ nmap -p 22 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-05-03 02:12 EDT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 1.54 seconds

(kali@kali)-[~/Documents]
$
```

Outcome

The target now exposes only SSH on port 2222. Fail2Ban automatically bans aggressive IPs after three failures. All other inbound traffic is blocked by UFW. The original exploit is no longer viable.